

National Financial Services Commission

Circular NFSC/CIR/2024/07

To: All Licensed Microfinance Banks, Payment Service Providers and Mortgage Institutions | Date: 14 August 2024 | Status: In force

Cybersecurity and Operational Resilience Framework

1. Purpose

This circular issues the Cybersecurity and Operational Resilience Framework for institutions licensed by the Commission. It replaces Circular NFSC/CIR/2021/03 in its entirety. Institutions are required to attain compliance in accordance with the phased schedule at section 6.

2. Scope

The Framework applies to all licensed microfinance banks, payment service providers, mortgage institutions and their outsourced technology providers where those providers process customer data or operate systems supporting a critical business service. It does not apply to institutions holding a representative office licence only.

3. Governance requirements

Each institution shall appoint a Chief Information Security Officer reporting functionally to the Board Risk Committee and administratively to the Managing Director. The role shall not be combined with that of Chief Information Officer or Head of Internal Audit. Institutions with total assets below NGN 5 billion may appoint a shared officer under a written arrangement notified to the Commission.

The Board shall review the institution's cyber risk appetite statement at least annually and shall receive a written report on cyber incidents at each ordinary meeting.

4. Technical control requirements

Institutions shall implement multi-factor authentication for all privileged accounts, all remote access, and all customer-facing channels permitting funds transfer. Authentication by SMS one-time password alone shall not satisfy this requirement for privileged accounts.

Institutions shall maintain an asset inventory covering all systems processing customer data, reviewed quarterly. Systems no longer receiving vendor security updates shall be recorded on a register of exceptions with a documented remediation date approved by the Board Risk Committee.

Customer data at rest shall be encrypted using an algorithm and key length consistent with prevailing international standards. Encryption keys shall be held separately from the encrypted data and access to keys shall be logged.

Institutions shall conduct penetration testing of internet-facing systems at least annually by an independent party, and shall submit the executive summary to the Commission within thirty days of completion.

5. Incident reporting

An institution shall notify the Commission of a material cyber incident within **seventy-two hours** of detection. A material incident is one that results in unauthorised access to customer data, disruption of a critical business service for more than four hours, or financial loss exceeding NGN 10 million.

A full incident report shall follow within fourteen days, addressing root cause, customer impact, remediation taken and controls introduced to prevent recurrence.

6. Implementation schedule

Requirement	Applicable institutions	Compliance date
Appointment of Chief Information Security Officer	All	31 December 2024
Multi-factor authentication, privileged accounts	All	31 December 2024
Multi-factor authentication, customer channels	All	31 March 2025
Asset inventory and exception register	All	31 March 2025
Encryption of customer data at rest	Assets above NGN 5bn	30 June 2025
Encryption of customer data at rest	Assets below NGN 5bn	31 December 2025
Annual independent penetration testing	All	30 June 2025
Board-approved cyber risk appetite statement	All	31 March 2025

7. Supervisory action

Failure to meet a compliance date without a written extension granted by the Commission attracts a penalty of NGN 2 million and a further NGN 100,000 for each day the breach continues. Persistent non-compliance may result in restriction of the institution's licence.

8. Enquiries

Enquiries concerning this circular should be directed to the Director, Prudential Supervision.